

Clase 225 — Seguridad en Google Cloud Platform

Parte: **10 — Seguridad en la nube y contenedores** · Fuente: *Google Cloud Security Foundations Guide y CIS Google Cloud Platform Foundation Benchmark* 🕒 Duración estimada: **120 min** · Nivel: **Intermedio**

🎯 Objetivo

Asegurar un proyecto de Google Cloud aplicando su jerarquía de recursos (organización, carpetas, proyectos), IAM basado en roles y service accounts, VPC y firewall, y los servicios de seguridad (Security Command Center, VPC Service Controls). Al terminar, el alumno sabrá endurecer un proyecto GCP conforme al CIS GCP Benchmark.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Estructurar** la jerarquía de recursos y heredar políticas desde la organización.
2. **Gestionar** IAM con roles predefinidos y service accounts sin claves estáticas.
3. **Configurar** VPC, reglas de firewall y Private Google Access.
4. **Habilitar** Security Command Center e interpretar sus hallazgos.
5. **Aplicar** Organization Policies para prevenir configuraciones inseguras.

📖 Temas

#	Tema	Por qué importa
1	Jerarquía: organización, carpetas, proyectos	Herencia de políticas y aislamiento
2	IAM y service accounts	Identidad de humanos y cargas
3	Organization Policies	Guardarraíles preventivos a escala
4	VPC y reglas de firewall	Segmentación de red
5	Security Command Center	CSPM y detección de amenazas
6	Cloud KMS y CMEK	Cifrado con claves gestionadas por el cliente
7	VPC Service Controls	Perímetros contra exfiltración de datos

📖 Definiciones y características

- **Jerarquía de recursos:** organización → carpetas → proyectos → recursos. *Clave:* las políticas IAM se heredan hacia abajo.
- **Service account:** identidad para cargas y automatización. *Clave:* evita claves descargables; usa Workload Identity.

- **Rol predefinido:** conjunto curado de permisos (viewer, editor, custom). *Clave:* evita el rol `Owner` salvo necesidad.
- **Organization Policy:** restricción declarativa a nivel de organización/carpeta. *Clave:* bloquea, por ejemplo, IPs públicas en VMs.
- **Firewall de VPC:** reglas allow/deny por prioridad y etiquetas. *Clave:* implícitamente deniega entrante y permite saliente.
- **Security Command Center (SCC):** panel central de postura y amenazas. *Clave:* detecta misconfiguraciones y actividad sospechosa.
- **VPC Service Controls:** perímetro de servicio que impide exfiltración. *Clave:* protege APIs gestionadas como Cloud Storage.

Herramientas y preparación

- CLI `gcloud` autenticada en un proyecto de laboratorio.
- **ScoutSuite** con proveedor `gcp` y **Prowler** (`prowler gcp`).
- Habilita las APIs necesarias antes de empezar (`gcloud services enable`).

```
# Ver la política IAM del proyecto
gcloud projects get-iam-policy my-lab-project
# Listar service accounts y sus claves
gcloud iam service-accounts list
gcloud iam service-accounts keys list --iam-account SA_EMAIL
```

Laboratorio guiado

1. Crea un proyecto de laboratorio dentro de una carpeta y aplica un rol `Viewer` a un usuario a nivel de carpeta; verifica la herencia hacia el proyecto.
2. Crea una **service account** para una carga y asígnale solo el rol mínimo. **No descargues una clave JSON**; usa Workload Identity o impersonación.
3. Aplica una **Organization Policy** que impida VMs con IP externa (`constraints/compute.vmExternalIpAddress`). Intenta crear una VM pública y confirma el bloqueo.
4. Configura una VPC con una regla de firewall que permita solo SSH desde un rango concreto vía IAP; deja el resto denegado por defecto.
5. Habilita **Security Command Center** (tier Standard) y revisa hallazgos de tipo *Public Bucket* o *Open Firewall*.
6. Cifra un bucket con **CMEK** usando una clave de Cloud KMS y revisa la política de la clave.
7. Ejecuta `prowler gcp --compliance cis_2.0_gcp` y corrige tres hallazgos de severidad alta; vuelve a ejecutar para verificar.

Ejercicios

1. Diseña una jerarquía de carpetas para separar producción, staging y sandbox.
2. Crea un rol personalizado que permita leer objetos de un bucket pero no listarlos.
3. Escribe una Organization Policy que restrinja las regiones donde se pueden crear recursos.
4. Configura Private Google Access para que una VM sin IP pública acceda a APIs de Google.
5. Interpreta un hallazgo de SCC de tipo `PUBLIC_BUCKET_ACL` .
6. Diseña un perímetro de VPC Service Controls alrededor de Cloud Storage.

Reto verificable

Endurece un proyecto de laboratorio: sin service account keys descargables, Organization Policy que prohíbe IPs externas, SCC habilitado, y al menos un bucket cifrado con CMEK.

Criterio de aceptación: crear una VM con IP externa es bloqueado por la policy, no existen claves de service account activas, y `prowler gcp` reporta como `PASS` los controles de IAM y de exposición pública que fallaban al inicio.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
<code>Permission denied</code> pese a rol asignado	Rol asignado en el ámbito equivocado; recuerda la herencia jerárquica.
Service account key filtrada en un repo	Se descargó una clave JSON; revócala y migra a Workload Identity.
VM sigue creándose con IP pública	Organization Policy en modo audit o no propagada; verifica el constraint y el ámbito.
Firewall "no bloquea" tráfico	La VPC permite saliente por defecto; añade reglas deny explícitas si hace falta.
SCC sin hallazgos	Tier Standard limitado; para detección avanzada activa Premium/Enterprise.

Preguntas frecuentes

? ¿Por qué evitar las claves JSON de service account? Son secretos de larga duración que suelen terminar en repositorios o discos. Workload Identity y la impersonación proveen credenciales temporales sin archivo que filtrar.

? ¿Organization Policy o IAM? Se complementan: IAM decide *quién puede hacer qué*; Organization Policy define *qué está permitido en absoluto* (guardarraíles), independientemente de los permisos IAM.

? ¿Qué protege VPC Service Controls que IAM no? IAM controla el acceso por identidad; VPC Service Controls crea un perímetro que impide que datos salgan a proyectos o redes fuera del perímetro aunque haya credenciales válidas, mitigando exfiltración.

Referencias

- Google Cloud Security Foundations Guide. <https://cloud.google.com/architecture/security-foundations>
- Google Cloud IAM docs. <https://cloud.google.com/iam/docs>
- Security Command Center. <https://cloud.google.com/security-command-center/docs>
- Organization Policy Service. <https://cloud.google.com/resource-manager/docs/organization-policy/overview>
- CIS Google Cloud Platform Foundation Benchmark. https://www.cisecurity.org/benchmark/google_cloud_computing_platform

Siguiente clase

Clase 226 - Ataques y pentest en entornos cloud